توثيق قواعد الأتمتة وكتيبات الاستجابة (Automation Rules & Playbooks)

1. مقدمة عن آلية العمل

يُعدّ محرك الاستجابة الآلية (Automation Engine) من أهم المكونات الأساسية في منصة EDR، حيث يقوم باكتشاف التهديدات والرد عليها في الوقت الفعلي للحد من الأضرار. تعتمد هذه المنظومة على عنصرين رئيسيين يعملان معاً: **قواعد الأتمتة (Automation Rules)** و **كتيبات الاستجابة (Playbooks)**.

متى وكيف تعمل المنظومة؟

1. **الالتقاط والتحليل (Detection & Alerting):** عندما يقوم وكيل الويندوز (Windows Agent) برصد نشاط مريب وتوجيهه للمحرك (Sigma Engine)، يتم إصدار تنبيه (Alert) يحتوي على معلومات دقيقة كنوع التهديد (Rule Name)، ومستوى الخطورة (Severity).
2. **التقييم عبر قواعد الأتمتة:** يقوم النظام بتمرير هذا التنبيه على سلسلة من **قواعد الأتمتة**. كل قاعدة تحتوي على "شروط تشغيل" (Trigger Conditions). إذا وافقت تفاصيل التنبيه (كالخطورة ونسبة الثقة) هذه الشروط، يتم تفعيل القاعدة المعنية.
3. **الاستجابة عبر الكتيبات (Playbooks):** كل قاعدة أتمتة ترتبط بشكل مباشر بـ **كتيب استجابة (Playbook)**. الكتيب هو مجموعة من الأوامر والخطوات المتسلسلة المعدة سلفاً.
4. **التنفيذ التلقائي (Auto-execute):** إذا كانت القاعدة مبرمجة على خيار التنفيذ التلقائي (Auto-execute = True)، سيقوم خادم الإدارة (Connection Manager) فوراً بدفع الأوامر إلى الوكيل (Agent) ليقوم بتطبيقها دون الحاجة لتدخل محلل أمن المعلومات. في حال تعطل هذا الخيار، يتم تقديم الكتيب للمحلل كـ "توصية" لاتخاذ القرار يدوياً.
5. **آلية التنفيذ والمهلة (Execution & Timeout):** تُرسل الأوامر لتصطف في طابور الوكيل. كل أمر لديه **مهلة زمنية (Timeout)** يُلغى إن تجاوزها، وسلوك يحدد ما إذا كان فشل الأمر سيتسبب بإيقاف تسلسل الكتيب (`on_failure: stop`) أو تجاوزه وتكملة باقي الأوامر (`continue`).
6. **فترة التبريد (Cooldown):** لمنع تكرار تفعيل الكتيب لنفس التهديد في فترات متقاربة واستهلاك الموارد، يتم تطبيق مدة توقف مؤقت (Cooldown) بعد كل تفعيل.

2. مُحسّن الذكاء الاصطناعي وتعلم الآلة (ML Optimizer)

يحتوي محرك الأتمتة على وحدة متقدمة لتعلم الآلة (ML Optimizer) تعمل في الخلفية لتحليل أداء القواعد وتقديم تحسينات مستمرة. توفر هذه الوحدة القدرات التالية:

1. **الترتيب الديناميكي للأولويات (Dynamic Rule Prioritization):**

عند ورود تنبيه، لا يعتمد المحرك على الأولوية الثابتة فقط بل يقوم بإعادة ترتيب القواعد بناءً على **معدل النجاح التاريخي (Success Rate)** خلال آخر 30 يوماً. القواعد التي أثبتت نجاحاً أكبر يتم إعطاؤها أولوية قصوى.

2. **التوصيات الذكية (Intelligent Suggestions):**

يقوم المحرك بتحليل بيانات التنفيذ (Execution Patterns) ويُصدر توصيات للمحللين في لوحة التحكم، منها:

- **تفعيل التشغيل التلقائي:** للقواعد اليدوية التي حققت نسبة نجاح ممتازة (> 95%) على مدار عمليات التشغيل.
- **تعطيل القواعد الضعيفة:** القواعد التي لها معدل نجاح منخفض (< 30%) وكثرة استخدام (False Positives)، يُوصى بتعطيلها مؤقتاً لمراجعتها.
- **ضبط فترات التبريد (Cooldown):** القواعد التي تعمل بسرعة وتتكرر بشكل عالٍ، يُوصى بزيادة فترة التبريد لتخفيف العبء.
- **تعديل نسبة الثقة (Confidence Threshold):** إذا أدى تقليل نسبة الثقة إلى معدل نجاح منخفض، يُقترح تعديل النسبة لتفادي الإنذارات الكاذبة.
- **رفع الأولوية للعمليات البطيئة:** إذا كانت القاعدة تأخذ وقتاً طويلاً جداً (أكثر من 30 دقيقة)، قد يقترح المحرك رفع أولويتها لتجنب تكدسها في طابور الأوامر.

3. **التنبؤ بنجاح القاعدة (Predicting Success):**

يتنبأ المحرك باحتمالية نجاح القاعدة قبل تشغيلها. إذا كان التنبيه في مستوى (Critical) أو بثقة عالية (> 0.9)، يتم رفع نسبة التنبؤ بالنجاح، مما يجعل النظام أكثر استجابة للتهديدات المؤكدة والخطيرة.

3. تفاصيل قواعد الأتمتة التسعة (Automation Rules 9)

تم إعداد وتكوين النظام ليحتوي على 9 قواعد أتمتة تُغطي مختلف جوانب الحماية، مفصلة كالآتي:

1. الاحتواء التلقائي للبرمجيات الخبيثة الحرجة (Critical Malware Auto-Containment)

- **الوصف:** الاستجابة اللحظية والفورية لأي برمجيات خبيثة تُصنف كحرجة لعزلها قبل انتشارها.
- **شروط التفعيل:** مستوى خطورة (Critical)، واحتواء التنبيه على أحد الأنماط (malware, trojan, backdoor, ransomware) بثقة تتجاوز 80%.
- **الكتيب المرتبط:** Malware Immediate Containment.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 1 - فترة التبريد: 30 دقيقة.

2. التحقيق التلقائي في الوصول المشبوه (Suspicious Access Auto-Investigation)

- **الوصف:** التحقيق التلقائي في محاولات تسجيل الدخول والوصول غير المصرح به ورفع الصلاحيات.

- **شروط التفعيل:** مستوى خطورة (High)، واحتواء التنبيه على أحد الأنماط (unauthorized_access, privilege_escalation, lateral_movement) بثقة تتجاوز 70%.
- **الكتيب المرتبط:** Unauthorized Access Investigation.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 2 - فترة التبريد: 15 دقيقة.

3. الاستجابة الطارئة لهجمات الفدية (Ransomware Emergency Response)

- **الوصف:** استجابة طارئة وحازمة فور اكتشاف أي عملية تشفير أو برمجية فدية لإيقاف التخريب.
- **شروط التفعيل:** مستوى خطورة (Critical)، واحتواء التنبيه على أحد الأنماط (ransomware, encryption, file_encryption) بثقة تتجاوز 90%.
- **الكتيب المرتبط:** Ransomware Attack Response.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 1 - فترة التبريد: 0 دقيقة (بدون توقف نظراً للحالة الطارئة).

4. التحليل المتقدم للتهديدات (Medium Threat Analysis)

- **الوصف:** التدخل والتحقيق المعمق في التهديدات ذات الخطورة المتوسطة التي قد تكون بداية لاختراق.
- **شروط التفعيل:** مستوى خطورة (Medium)، واحتواء التنبيه على أحد الأنماط (suspicious, anomalous, unusual_behavior) بثقة تتجاوز 60%.
- **الكتيب المرتبط:** Advanced Malware Analysis.
- **إعدادات التشغيل:** **تنفيذ يدوي فقط (كتوصية)** - الأولوية: 3 - فترة التبريد: 60 دقيقة.

5. الإزالة التلقائية للبرمجيات الخبيثة (Malware Auto-Removal)

- **الوصف:** اتخاذ خطوات هجومية لإزالة التهديد المكتشف وعزل الملفات.
- **شروط التفعيل:** مستوى خطورة (Critical أو High)، واحتواء التنبيه على أحد الأنماط (malware_detected, trojan_found) بثقة تتجاوز 85%.
- **الكتيب المرتبط:** Malware Removal & Recovery.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 2 - فترة التبريد: 45 دقيقة.

6. التحقق من صحة النظام بعد الحادثة (Post-Incident Validation)

- **الوصف:** قاعدة تُفعل للتأكد من نظافة النظام بعد إجراء عملية استجابة لحادثة أمنية، لضمان عدم وجود بقايا.
- **شروط التفعيل:** مستوى خطورة (Medium أو Low)، وأنماط (post_incident, validation, health_check) بثقة تتجاوز 50%.
- **الكتيب المرتبط:** System Validation Check.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 4 - فترة التبريد: 120 دقيقة.

7. الاحتواء المباشر لسلوك الفدية المشتبه به (Auto-Contain Suspected Ransomware)

- **الوصف:** قاعدة سريعة تعتمد على اسم القاعدة التنبيهية (Sigma Rule) بشكل مباشر لعزل هجمات الفدية المعتمدة على السلوك.
- **شروط التفعيل:** تنبيه ناتج تحديداً عن القاعدة المسماة "Ransomware Behavior Detected".
- **الكتيب المرتبط:** Ransomware Immediate Containment.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 1 - فترة التبريد: 5 دقائق.

8. حظر وسائط التخزين غير الموثوقة (Block Untrusted Mass Storage)

- **الوصف:** قاعدة فورية تُعنى بمنع تسريب البيانات عن طريق فصل أجهزة USB غير المألوفة.
- **شروط التفعيل:** تنبيه ناتج تحديداً عن القاعدة المسماة "Unauthorized USB Inserted".
- **الكتيب المرتبط:** Unauthorized USB Device Response.
- **إعدادات التشغيل:** تنفيذ تلقائي (نعم) - الأولوية: 3 - فترة التبريد: 5 دقائق.

9. إنهاء العمليات عالية الخطورة (High Risk Process Termination)

- **الوصف:** إيقاف عمل أدوات سرقة كلمات المرور (مثل Mimikatz) عند رصدها لتجنب تسرب بيانات الدخول.
- **شروط التفعيل:** تنبيه ناتج تحديداً عن القاعدة المسماة "Credential Dumping Tool".
- **الكتيب المرتبط:** Deep Malware Investigation.
- **إعدادات التشغيل: تنفيذ يدوي فقط** - الأولوية: 2 - فترة التبريد: 5 دقائق.

4. تفاصيل كتيبات الاستجابة التسعة (9 Playbooks)

هذه الكتيبات تحدد بدقة ما يفعله الوكيل (Agent) عند استلام أمر الاستجابة.

1. Malware Immediate Containment (الاحتواء الفوري للبرمجيات الخبيثة)

- **الهدف:** قطع اتصال المضيف وجمع بيانات سريعة عن الحادث.
- **تكتيكات MITRE:** T1055, T1059, T1566
- **خطوات التنفيذ:**
  i. **عزل الشبكة (`isolate_network`):** عزل الجهاز مع إبقاء الاتصال بالخادم. المهلة 300 ثانية. التوقف التام في حال الفشل.
  ii. **جمع الأدلة الجنائية (`collect_forensics`):** سحب آخر 1000 سجل للعمليات، الملفات، الشبكة، وغيرها. المهلة 900 ثانية.
  iii. **عزل ملف مشبوه (`quarantine_file`):** حجز ملف مشتبه به في `C:\Windows\Temp` . المهلة 300 ثانية.

2. Ransomware Attack Response (الاستجابة لهجمات الفدية)

- **الهدف:** التعامل الصارم والشامل مع عمليات التشفير لإنقاذ الملفات.
- **تكتيكات MITRE:** T1486, T1059, T1055
- **خطوات التنفيذ:**
  i. **عزل الشبكة (`isolate_network`):** مهلة 300 ثانية، توقف عند الفشل.
  ii. **إيقاف عملية التشفير (`terminate_process`):** إيقاف عملية `vssadmin.exe` (التي تحذف النسخ الاحتياطية) مع كامل شجرة العمليات الخاصة بها. المهلة 300 ثانية.
  iii. **جمع أدلة موسع (`collect_forensics`):** سحب حتى 2000 حدث للعمليات والملفات والسجلات. المهلة 1200 ثانية.
  iv. **لقطة للذاكرة (`memory_dump`):** سحب نسخة كاملة من الذاكرة العشوائية للحفاظ على مفاتيح التشفير للتحليل لاحقاً. المهلة 1800 ثانية.

3. Advanced Malware Analysis (التحليل المتقدم للبرمجيات الخبيثة)

- **الهدف:** تنفيذ فحص وتحليل عميق في بيئة الجهاز دون التأثير على تشغيله بشكل كامل.
- **تكتيكات MITRE:** T1055, T1543, T1547
- **خطوات التنفيذ:**
  i. **جمع بيانات (`collect_forensics`):** حتى 1500 حدث. المهلة 900 ثانية.
  ii. **لقطة لشجرة العمليات (`process_tree_snapshot`):** للحصول على هيكلية العمليات الفاعلة حالياً. المهلة 600 ثانية.
  iii. **فحص الاستمرارية (`persistence_scan`):** للكشف عن أي آليات بقاء للبرمجيات الخبيثة داخل النظام. المهلة 900 ثانية.
  iv. **التسلسل الزمني لنظام الملفات (`filesystem_timeline`):** آخر 24 ساعة من التغييرات. المهلة 600 ثانية.

4. Unauthorized Access Investigation (التحقيق في الوصول غير المصرح به)

- **الهدف:** تعقب المخترقين ومحاولات سرقة الصلاحيات عبر الشبكة.
- **تكتيكات MITRE:** T1078, T1110, T1003
- **خطوات التنفيذ:**
  i. **جمع بيانات المصادقة (`collect_forensics`):** السحب المخصص لسجلات المصادقة والشبكة. المهلة 600 ثانية.
  ii. **مراجعة الوصول إلى LSASS (`lsass_access_audit`):** كشف عمليات حقن الذاكرة وسرقة كلمات المرور. المهلة 300 ثانية.
  iii. **آخر اتصالات الشبكة (`network_last_seen`):** توثيق الجهات التي اتصل بها النظام مؤخراً. المهلة 300 ثانية.
  iv. **فحص سلامة الوكيل (`agent_integrity_check`):** للتأكد من أن المخترق لم يقم بتعطيل الوكيل الأمني. المهلة 300 ثانية.

5. Malware Removal & Recovery (إزالة البرمجيات الخبيثة واستعادة النظام)

- **الهدف:** عملية تنظيف وعودة للوضع الطبيعي بعد التأكد من عزل التهديد.
- **تكتيكات MITRE:** T1059, T1055, T1566
- **خطوات التنفيذ:**
  i. **إنهاء العملية المشبوهة (`terminate_process`):** إغلاق الملف التنفيذي المسبب. المهلة 300 ثانية.
  ii. **عزل الملف (`quarantine_file`):** حجر الملف من النظام لتجنب تشغيله مجدداً. المهلة 300 ثانية.
  iii. **تحديث قواعد البيانات التوقيعية (`update_signatures`):** استدعاء تحديث لملفات YARA وغيرها. المهلة 600 ثانية.
  iv. **إعادة اتصال الشبكة (`unisolate_network`):** فك العزل لعودة الجهاز لبيئة العمل. المهلة 300 ثانية.

6. System Validation Check (التحقق من صحة النظام)

- **الهدف:** تقييم روتيني يضمن خلو النظام من العيوب واستعداده للتصدي للتهديدات.
- **تكتيكات MITRE:** T1082, T1018
- **خطوات التنفيذ:**
  i. **جمع بيانات صحة النظام (`collect_forensics`):** فحص لـ 500 حدث أمني وسجلي. المهلة 300 ثانية.
  ii. **فحص سلامة الوكيل (`agent_integrity_check`):** للتأكد من التشغيل السليم. المهلة 300 ثانية.
  iii. **تحديث التوقيعات (`update_signatures`):** تحديث قواعد التهديد من المسار المخصص. المهلة 600 ثانية.

7. Ransomware Immediate Containment (احتواء هجمات الفدية الفوري)

- **الهدف:** رد فعل آلي خفيف وسريع جداً لإيقاف التشفير مبكراً.
- **تكتيكات MITRE:** T1486, T1490
- **خطوات التنفيذ:**
  i. **عزل الشبكة (`isolate_network`):** مهلة 30 ثانية. فصل الاتصال كخطوة أولى.
  ii. **إيقاف العمليات المشبوهة (`terminate_process`):** استهداف السلوك الاستكشافي للفدية وإنهائه فوراً. المهلة 45 ثانية.
  iii. **جمع لقطة سريعة للذاكرة (`collect_forensics`):** مهلة 300 ثانية.

8. Unauthorized USB Device Response (الاستجابة لربط وسائط الـ USB غير الموثوقة)

- **الهدف:** حماية البيانات من السرقة المادية أو دخول الفيروسات عبر المنافذ.
- **تكتيكات MITRE:** T1091, T1052
- **خطوات التنفيذ:**
  i. **أمر موجه لفصل القطعة (`run_cmd`):** إرسال أمر عبر الـ PowerShell بقيمة `Get-Volume | Where-Object DriveType -eq Removable | Dismount-Volume` لفصل وإلغاء تحميل أي وسيط تخزين قابل للإزالة. المهلة 15 ثانية.

ii. **سحب السجلات (`collect_logs`):** سحب سجلات الحماية (Security) والنظام (System) لمراجعة هوية الـ USB المتصل. المهلة 60 ثانية.

9. Deep Malware Investigation (التحقيق العميق في البرمجيات الخبيثة)

- **الهدف:** مطاردة واكتشاف برمجيات التجسس المتخفية باستخدام التوقيعات وسجلات الإقلاع.
- **تكتيكات MITRE:** T1547, T1053
- **خطوات التنفيذ:**

i. **فحص توقيعي شامل (`scan_file`):** تنفيذ فحص YARA مخصص على مجلدات محددة مثل `C:\Windows\Temp` . المهلة 600 ثانية.

ii. **فحص مفاتيح الإقلاع (`run_cmd`):** إرسال أمر لتشغيل `reg query` لمفاتيح `Run/RunOnce` في الريجستري (Registry) للبحث عن أي برمجيات مبرمجة للعمل عند الإقلاع. المهلة 120 ثانية.